PRAVEEN V 241901082

Exercise 12
Identify Cross-Site Scripting (XSS) Vulnerabilities

AIM

To investigate XSS vulnerabilities in an authorized training application by identifying input fields where user-supplied content is displayed, and to differentiate reflected XSS from stored XSS based on observed application behavior.

PROCEDURE

a) Identifying Input Fields Where User-Supplied Content Is Displayed

1. Open the target web application in a browser and browse through all pages containing input fields (search box, login form, comment/guestbook form, profile fields).
2. For each input field, enter a harmless marker string (e.g., testxss123) and submit it.
3. Observe the resulting page to check whether the entered value is reflected back or displayed anywhere on the page (directly in the response, in an error message, or in a listing).
4. Note down all input fields where the submitted content appears in the output, as these are candidate injection points.
5. View the page source (Ctrl+U) at each candidate point to check whether the input is inserted without proper encoding/sanitization.

b) Differentiating Reflected XSS from Stored XSS

1. At each candidate input field, submit a test payload: <script>alert('XSS')</script>
2. If the alert box appears immediately on the same response page (e.g., search results page) and disappears after refreshing/revisiting without resubmitting, record it as Reflected XSS.
3. If the alert box appears every time the page is revisited or appears on a different page/for other users (e.g., a comment stored and shown on the guestbook page), record it as Stored XSS.
4. Repeat the test on each identified input field and note the type of XSS observed, along with the URL/parameter where the payload executed.
5. Record all findings in the observation table.

OBSERVATION TABLE

S.No	Input Field / Page	Payload Used	Behavior Observed	XSS Type
1	Search box (/search.php)	<script>alert('XSS')</script>	Alert executed only in the search results response	Reflected XSS
2	Guestbook	<script>alert('XSS')</	Alert	Stored

S.No	Input Field / Page	Payload Used	Behavior Observed	XSS Type
	comment field	script>	executed every time the guestbook page is loaded	XSS
3	Login username field	<script>alert('XSS')</ script>	Payload rejected, no execution	Not vulnerable
4	Product search parameter (URL)	<script>alert('XSS')</ script>	Alert executed immediatel y from the URL response	Reflected XSS

OUTPUT

Reflected XSS test (search field):

Request: GET /search.php?test=<script>alert('XSS')</script>

Response: Results for <script>alert('XSS')</script> ... (script executes on page load)

Stored XSS test (guestbook field):

Submitted comment: <script>alert('XSS')</script>

Stored in database and rendered on every visit to /guestbook.php

Alert box appears for any user viewing the guestbook page

Page source confirming no sanitization:

<script>alert('XSS')</script>

RESULT

Thus, XSS vulnerabilities in the authorized training application were successfully investigated. Input fields reflecting user-supplied content were identified, and the application behavior confirmed the presence of both reflected XSS (search parameter) and stored XSS (guestbook comment field).